Contents

1 Respond to security incidents (35–40%) 5

1.1 Respond to alerts and incidents in Microsoft Defender XDR . . . 5

1.1.1 Investigate and remediate threats by using Microsoft Defender for Office 365, including automatic attack disruption . . . 5

1.1.1.1 Investigación desde un incidente . . . 5

1.1.1.2 Threat Explorer . . . 5

1.1.1.3 Latest delivery location . . . 6

1.1.1.4 Email entity page . . . 7

1.1.1.5 Campaigns . . . 7

1.1.1.6 Acciones de remediación sobre email . . . 8

1.1.1.7 Remediación de mensajes mediante AIR . . . 8

1.1.1.8 Automated remediation . . . 9

1.1.1.9 ZAP . . . 9

1.1.2 Investigate and remediate threats or compromised entities identified by Microsoft Purview . . . 10

1.1.2.1 Purview DLP . . . 10

1.1.2.2 Correlación XDR . . . 11

1.1.2.3 Go Hunt . . . 11

1.1.2.4 Remediación sobre archivos . . . 11

1.1.2.5 Remediación sobre usuario o dispositivo . . . 12

1.1.2.6 Insider Risk Management . . . 12

1.1.2.7 Correlación por usuario . . . 13

1.1.2.8 Advanced Hunting para Insider Risk . . . 13

1.1.2.9 Escenarios típicos de examen . . . 13

1.1.3 Investigate and remediate alerts and incidents identified by Microsoft Defender for Cloud workload protections . . . 14

1.1.3.1 Identificar alertas de Defender for Cloud . . . 15

1.1.3.2 Attack story y Assets . . . 15

1.1.3.3 Alertas informativas . . . 16

1.1.3.4 Advanced Hunting . . . 16

1.1.3.5 Remediación . . . 16

1.1.3.6 Mitigate the threat . . . 17

1.1.3.7 Prevent future attacks . . . 17

1.1.3.8 Automated response . . . 18

1.1.3.9 Suppress similar alerts . . . 18

1.1.3.10 Sincronización de estado . . . 18

1.1.3.11 Defender for Cloud + Sentinel . . . 19

1.1.3.12 Escenarios típicos de examen . . . 19

1.1.4 Investigate and remediate security risks identified by Microsoft Defender for Cloud Apps . . . 20

1.1.4.1 Activity log . . . 20

1.1.4.2 Investigación de una identidad . . . 20

1.1.4.3 Require user to sign in again . . . 21
1.1.4.4 Confirm user compromised . . . 21
1.1.4.5 CloudAppEvents . . . 21
1.1.4.6 Cloud Discovery . . . 22
1.1.4.7 Conditional Access App Control . . . 22
1.1.4.8 Access policies . . . 22
1.1.4.9 Session policies . . . 23
1.1.4.10 Escenarios típicos de examen . . . 23
1.1.5 Investigate and remediate compromised identities that are identified by Microsoft Entra ID . . . 24
1.1.5.1 Investigación . . . 24
1.1.5.2 Investigación en Defender XDR . . . 25
1.1.5.3 Acciones sobre un risky user . . . 25
1.1.5.4 Confirm compromised . . . 25
1.1.5.5 Remediación . . . 25
1.1.5.6 Self-remediation mediante Conditional Access . 26
1.1.5.7 Leaked credentials . . . 27
1.1.5.8 Escenarios típicos de examen . . . 27
1.1.6 Investigate and remediate security alerts from Microsoft Defender for Identity . . . 28
1.1.6.1 Alert story . . . 28
1.1.6.2 Identity page . . . 28
1.1.6.3 Lateral movement . . . 29
1.1.6.4 Alertas típicas . . . 29
1.1.6.5 Respuesta sobre identidades . . . 30
1.1.6.6 Disable . . . 30
1.1.6.7 Force password change . . . 30
1.1.6.8 Revoke session . . . 30
1.1.6.9 Mark as compromised . . . 31
1.1.6.10 Action accounts . . . 31
1.1.6.11 Action Center . . . 31
1.1.6.12 Advanced Hunting . . . 31
1.1.6.13 Escenarios típicos de examen . . . 32
1.1.7 Investigate and remediate alerts and incidents identified by Microsoft Sentinel . . . 32
1.1.7.1 Flujo de investigación . . . 33
1.1.7.2 Attack story . . . 33
1.1.7.3 Assets y entity pages . . . 34
1.1.7.4 Timeline . . . 34
1.1.7.5 Top insights . . . 35
1.1.7.6 Logs y Advanced Hunting . . . 35
1.1.7.7 Similar incidents . . . 36
1.1.7.8 Tasks . . . 36
1.1.7.9 Investigation graph . . . 36
1.1.7.10 Escenarios típicos de examen . . . 36

1.1.8 Investigate incidents by using agentic AI, including embedded Microsoft Security Copilot . . . 37
1.1.8.1 Embedded Security Copilot . . . 37
1.1.8.2 Incident summary . . . 38
1.1.8.3 Análisis de scripts y command lines . . . 38
1.1.8.4 Agentic AI . . . 39
1.1.8.5 Security Alert Triage Agent . . . 39
1.1.8.6 Transparent reasoning . . . 40
1.1.8.7 Security Store . . . 40
1.1.8.8 Human in the loop . . . 41
1.1.8.9 Escenarios típicos de examen . . . 41
1.1.9 Investigate complex attacks, such as multi-stage, multi-domain, and lateral movement . . . 41
1.1.9.1 Tipos de ataques complejos . . . 42
1.1.9.2 Attack story . . . 42
1.1.9.3 Flujo de investigación . . . 42
1.1.9.4 Multi-domain investigation . . . 43
1.1.9.5 Escenarios típicos de examen . . . 43
1.1.10 Manage security incidents by using case management . . . 44
1.1.10.1 Case types . . . 44
1.1.10.2 Propiedades del case . . . 45
1.1.10.3 Priority y ownership . . . 45
1.1.10.4 Tasks . . . 45
1.1.10.5 Attachments . . . 46
1.1.10.6 Merge incident cases . . . 46
1.1.10.7 Move alerts . . . 46
1.1.10.8 Auditoría mediante KQL . . . 46
1.1.10.9 Permisos . . . 46
1.1.10.10 Escenarios típicos de examen . . . 46
1.2 Respond to alerts and incidents in Microsoft Defender for Endpoint 48
1.2.1 Investigate device timelines . . . 48
1.2.1.1 Qué investigar . . . 48
1.2.1.2 Process tree . . . 49
1.2.1.3 Filtros . . . 49
1.2.1.4 Hunt for related events . . . 49
1.2.1.5 Escenarios típicos de examen . . . 50
1.2.2 Perform actions on the device, including live response and collecting investigation packages . . . 50
1.2.2.1 Principales device actions . . . 50
1.2.2.2 Live Response . . . 50
1.2.2.3 Live Response library . . . 51
1.2.2.4 Investigation package . . . 51
1.2.2.5 Action Center . . . 52
1.2.2.6 Escenarios típicos de examen . . . 52
1.2.3 Perform evidence and entity investigation . . . 52
1.2.3.1 Evidence . . . 53

1.2.3.2 Entity investigation . . . 53
1.2.3.3 Advanced Hunting . . . 54
1.2.3.4 Escenarios típicos de examen . . . 54
1.2.4 Investigate and remediate incidents identified by automatic attack disruption . . . 54
1.2.4.1 Attack disruption summary . . . 55
1.2.4.2 Investigar el incidente . . . 55
1.2.4.3 Activities . . . 55
1.2.4.4 Action Center . . . 56
1.2.4.5 Liberar assets contenidos . . . 56
1.2.4.6 Escenarios típicos de examen . . . 57
1.3 Investigate Microsoft 365 activities to identify threats . . . 58
1.3.1 Investigate threats by using Microsoft Purview Audit . . . 58
1.3.1.1 Audit search . . . 58
1.3.1.2 Resultados . . . 59
1.3.1.3 Actividades especialmente relevantes . . . 59
1.3.1.4 MailItemsAccessed . . . 59
1.3.1.5 Exportar resultados . . . 60
1.3.1.6 Retención . . . 60
1.3.1.7 Escenarios típicos de examen . . . 60
1.3.2 Investigate threats by using Content search in Microsoft Purview eDiscovery . . . 61
1.3.2.1 Content locations . . . 61
1.3.2.2 Crear una búsqueda . . . 61
1.3.2.3 Operadores . . . 62
1.3.2.4 Review search results . . . 62
1.3.2.5 Review set . . . 63
1.3.2.6 Export . . . 63
1.3.2.7 Escenarios típicos de examen . . . 64
1.3.3 Investigate threats by using Microsoft Graph activity logs 64
1.3.3.1 Configuración . . . 64
1.3.3.2 Tabla principal . . . 65
1.3.3.3 Campos más importantes . . . 65
1.3.3.4 Correlación con sign-in logs . . . 65
1.3.3.5 Ejemplo: llamadas no autorizadas . . . 66
1.3.3.6 Escenarios típicos de examen . . . 66

1 Respond to security incidents (35–40%)

1.1 Respond to alerts and incidents in Microsoft Defender XDR

1.1.1 Investigate and remediate threats by using Microsoft Defender for Office 365, including automatic attack disruption

Microsoft Defender for Office 365 permite investigar amenazas de correo y colaboración desde varias vistas del Microsoft Defender portal.

Las herramientas más importantes para SC-200 son:

- **Incidents**;
- **Threat Explorer / Real-time detections**;
- **Email entity page**;
- **Campaigns**;
- **Evidence and response**;
- **Action Center**.

1.1.1.1 Investigación desde un incidente

La ruta principal es:

Microsoft Defender portal → Incidents

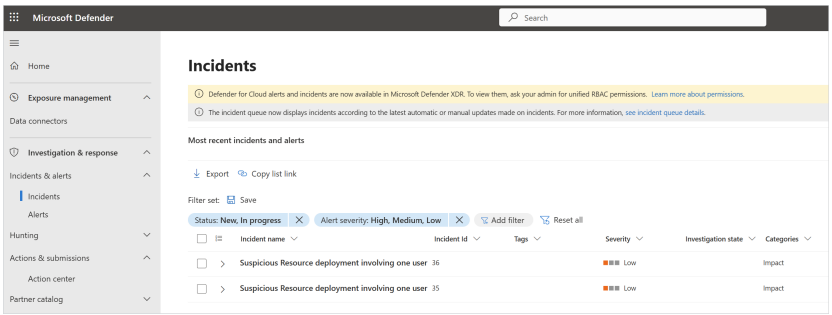


Figure 1: Caption

1.1.1.2 Threat Explorer

En Defender for Office 365 Plan 2 se dispone de:

Email & collaboration → Explorer

también denominado:

Threat Explorer

Permite investigar:

- phishing;
- malware;
- URLs maliciosas;
- archivos adjuntos;
- usuarios afectados;
- mensajes entregados;
- clicks sobre URLs.

Defender for Office 365 Plan 1 dispone de:

Real-time detections

con capacidades de investigación más limitadas.
Por tanto:

Threat Explorer = Plan 2

Real-time detections = Plan 1

1.1.1.3 Latest delivery location

Durante la investigación debe comprobarse especialmente:

Latest delivery location

porque indica dónde se encontraba el mensaje después de las acciones ejecutadas por Microsoft 365 o por un administrador.
Por ejemplo:

- Inbox;
- Junk;
- Deleted Items;
- Quarantine;
- Soft deleted.

Esto permite determinar si:

el correo malicioso continúa dentro del buzón y necesita remediación.

1.1.1.4 Email entity page

Desde un mensaje puede abrirse:

Open email entity

para analizarlo en profundidad.
También dispone de una:

Timeline

que muestra eventos posteriores a la entrega, como:

- ZAP;
- acciones de administración;
- liberación desde cuarentena.

1.1.1.5 Campaigns

Defender for Office 365 Plan 2 puede agrupar ataques coordinados de phishing y malware en:

Campaigns

Ruta:

Email & collaboration → Campaigns

Una campaign permite analizar:

- número de mensajes;
- usuarios afectados;
- infraestructura atacante;
- URLs;
- clicks;
- evolución temporal;
- ubicación actual de los mensajes.

Por tanto:

Campaign = varios mensajes relacionados pertenecientes al mismo ataque

y no simplemente un único email malicioso.

1.1.1.6 Acciones de remediación sobre email

Desde Incidents, Evidence and response o Threat Explorer pueden realizarse acciones como:

- **Move to Inbox**;
- **Move to Junk**;
- **Move to Deleted Items**;
- **Soft delete**;
- **Hard delete**.

Para el examen:

Soft delete

mueve el mensaje a:

Recoverable Items \ Deletions

por lo que puede recuperarse.
Mientras que:

Hard delete

purga el mensaje de forma más agresiva.

1.1.1.7 Remediación de mensajes mediante AIR

El funcionamiento general de AIR ya se ha tratado anteriormente.
En Defender for Office 365 interesa recordar únicamente que AIR analiza:

el mensaje original + mensajes similares relacionados

y crea:

email clusters

para determinar el alcance del ataque.
Los clusters pueden recibir verdicts como:

- Malicious;
- Suspicious;
- No threats found.

Para clusters clasificados como Malicious debido a:

- malware;

- high confidence phishing;
- malicious URL;
- malicious file;

Defender puede recomendar:

Soft delete

para los mensajes que continúan en buzones cloud.

1.1.1.8 Automated remediation

Puede configurarse desde:

Settings → Email & collaboration → MDO automation settings

para que determinados clusters maliciosos sean remediados automáticamente sin aprobación del SOC.

Un límite importante es:

clusters de más de 10.000 mensajes no se remediarán automáticamente

y permanecerán como:

Pending action

para revisión.

1.1.1.9 ZAP

No debe confundirse AIR con:

Zero-hour Auto Purge (ZAP)

ZAP actúa:

después de que el correo haya sido entregado

si Microsoft determina posteriormente que se trata de:

- phishing;
- spam;
- malware.

Conceptualmente:

ZAP = post-delivery protection

mientras que AIR investiga el alcance completo y puede recomendar o ejecutar acciones adicionales.

1.1.2 Investigate and remediate threats or compromised entities identified by Microsoft Purview

Microsoft Purview puede aportar a Microsoft Defender XDR señales relacionadas principalmente con:

- **Data Loss Prevention (DLP)**;
- **Insider Risk Management (IRM)**.

Estas señales permiten correlacionar riesgos sobre:

- usuarios;
- dispositivos;
- archivos;
- emails;
- ubicaciones de Microsoft 365;

con otras señales de seguridad de Defender XDR.

1.1.2.1 Purview DLP

Las políticas:

Microsoft Purview Data Loss Prevention

pueden detectar acciones sobre información sensible, por ejemplo:

- compartir información sensible;
- copiar archivos;
- subir información a servicios cloud;
- enviar información mediante correo;
- transferir datos desde endpoints.

Cuando las alertas DLP están habilitadas, pueden investigarse desde:

Microsoft Defender portal → Incidents & alerts

filtrando por:

Service source = Microsoft Data Loss Prevention

1.1.2.2 Correlación XDR

Una alerta DLP puede correlacionarse dentro del mismo incidente con señales procedentes de:

- Defender for Endpoint;
- Defender for Office 365;
- Microsoft Entra ID;
- Microsoft Sentinel;
- otras señales DLP.

Por tanto, una violación DLP puede pasar de ser:

una simple infracción de política

a convertirse en evidencia de:

una cuenta o dispositivo comprometido

cuando se correlaciona con otras señales.

1.1.2.3 Go Hunt

Desde un evento DLP puede utilizarse:

Go Hunt

para ampliar la investigación mediante Advanced Hunting.
Defender proporciona consultas predefinidas relevantes según el origen.
Por ejemplo, para SharePoint:

- File shared with;
- File activities;
- Site activity;
- User DLP violations for last 30 days.

1.1.2.4 Remediación sobre archivos

Si el evento afecta a un archivo de:

SharePoint Online / OneDrive for Business

pueden ejecutarse acciones como:

- **Unshare**;
- **Delete**;
- **Apply sensitivity label**;
- **Apply retention label**;
- Download, si se dispone de permisos.

1.1.2.5 Remediación sobre usuario o dispositivo

Desde las entidades:

User

y:

Device

puede abrirse la página correspondiente de Defender XDR y ejecutar acciones compatibles.

Para una identidad comprometida pueden estar disponibles:

- **Disable user**;
- **Revoke sessions**;
- **Force password change**;
- **Mark user as compromised**.

Para un dispositivo comprometido pueden utilizarse, según licencia y configuración:

- **Isolate device**;
- Run antivirus scan;
- Collect investigation package;
- acciones sobre archivos maliciosos.

Por tanto:

DLP detecta la actividad; Defender XDR puede remediar la entidad comprometida.

1.1.2.6 Insider Risk Management

Microsoft Purview:

Insider Risk Management

detecta comportamientos potencialmente riesgosos asociados a usuarios, como:

- exfiltración de información;
- filtración de datos;
- robo de propiedad intelectual;
- violaciones de políticas internas.

Sus alertas pueden visualizarse en Defender XDR filtrando por:

Service source = Microsoft Purview Insider Risk Management

1.1.2.7 Correlación por usuario

Las alertas IRM asociadas a un usuario pueden correlacionarse en un mismo incidente con:

- Purview DLP;
- Microsoft Entra ID;
- Defender for Endpoint;
- otras soluciones Defender.

1.1.2.8 Advanced Hunting para Insider Risk

Los datos principales disponibles son:

Tabla	**Información**
`AlertInfo`	Información sobre alertas IRM.
`AlertEvidence`	Entidades asociadas a las alertas.
`DataSecurityBehaviors`	Comportamientos potencialmente sospechosos identificados por Purview.
`DataSecurityEvents`	Eventos enriquecidos relacionados con actividades de usuario.

Para investigar:

qué hizo el usuario

son especialmente importantes:

`DataSecurityBehaviors` + `DataSecurityEvents`

1.1.2.9 Escenarios típicos de examen

Escenario 1: DLP detecta que un usuario compartió externamente un documento confidencial en SharePoint.

Investigar DLP alert → Unshare / Apply sensitivity label

Escenario 2: una alerta DLP coincide con inicios de sesión maliciosos de la misma cuenta.

Investigar User entity → posible compromised identity

y aplicar acciones como:

Revoke sessions / Disable user

Escenario 3: se quiere analizar todo el comportamiento asociado a una alerta Insider Risk.

Advanced Hunting → `DataSecurityEvents` / `DataSecurityBehaviors`

Escenario 4: no aparecen detalles de riesgo IRM en la página del usuario de Defender.

Comprobar:

Share user risk details with other security solutions

Escenario 5: después del cambio de octubre de 2026 una señal DLP ya no aparece en la cola de alertas.

Comprobar `BehaviorInfo/BehaviorEntities` y la built-in Alert Tuning rule.

1.1.3 Investigate and remediate alerts and incidents identified by Microsoft Defender for Cloud workload protections

Microsoft Defender for Cloud aporta a Microsoft Defender XDR alertas procedentes de workloads protegidas en:

- Azure;
- AWS;
- Google Cloud.

Las alertas pueden afectar, entre otros, a:

- virtual machines;
- containers/Kubernetes;
- storage;
- databases;
- cloud control plane;
- AI workloads.

Defender XDR correlaciona estas señales con identidades, dispositivos y otras workloads para mostrar el ataque completo.

1.1.3.1 Identificar alertas de Defender for Cloud

Las alertas de Defender for Cloud aparecen en las colas normales de:

Incidents & alerts

del Microsoft Defender portal.
Dentro de la alerta o incidente debe identificarse especialmente:

- **cloud resource afectado**;
- plataforma: Azure, AWS o GCP;
- subscription/account/project;
- resource type;
- severity;
- actividad detectada;
- IPs, processes, files u otras evidencias.

Los recursos cloud aparecen como:

Cloud resource assets

dentro del incidente.

1.1.3.2 Attack story y Assets

La integración permite incluir el recurso cloud directamente en:

Attack story

y:

Assets

del incidente.
Esto permite relacionar, por ejemplo:

Compromised account

⇓

Malicious cloud control-plane operation

⇓

Compromised VM / Kubernetes workload

sin investigar cada producto por separado.
Las virtual machines pueden disponer además de su propia:

entity page

con alertas y actividad relacionada.

1.1.3.3 Alertas informativas

Un detalle importante es que:

> **Informational Defender for Cloud alerts no se integran en Microsoft Defender XDR**

para reducir ruido.

Por tanto, la ausencia de una alerta Informational en Defender XDR:

> **no implica necesariamente que no exista en Defender for Cloud.**

1.1.3.4 Advanced Hunting

La integración amplía Advanced Hunting con tablas específicas de Defender for Cloud.

Las más importantes son:

Tabla	Uso
`CloudAuditEvents`	Actividad de control plane en cloud, incluida actividad Azure Resource Manager y Kubernetes audit.
`CloudProcessEvents`	Procesos ejecutados dentro de infraestructura cloud y Kubernetes.
`CloudStorageAggregatedEvents`	Actividad sobre almacenamiento cloud y operaciones sobre archivos/datos.
`CloudDnsEvents`	Actividad DNS procedente de infraestructura cloud.

Por ejemplo:

```
CloudProcessEvents
| where ProcessCommandLine has "curl"
```

puede utilizarse para investigar procesos sospechosos ejecutados dentro de workloads cloud.

1.1.3.5 Remediación

En Defender for Cloud, la pestaña:

> **Take action**

proporciona las acciones recomendadas.

Se divide principalmente en:

- **Inspect resource context**;
- **Mitigate the threat**;
- **Prevent future attacks**;
- **Trigger automated response**;
- **Suppress similar alerts**.

1.1.3.6 Mitigate the threat

Mitigate the threat proporciona instrucciones específicas para contener o eliminar la amenaza.

La acción concreta depende del workload.
Por ejemplo:

- detener o eliminar un proceso malicioso;
- eliminar archivos maliciosos;
- corregir una configuración comprometida;
- revocar credenciales;
- aislar o reconstruir un recurso;
- corregir un container o workload Kubernetes comprometido.

Para SC-200:

Responder al ataque actual → Mitigate the threat

1.1.3.7 Prevent future attacks

Después de eliminar la amenaza pueden aparecer:

security recommendations

destinadas a reducir la probabilidad de repetición.
Por ejemplo:

- corregir configuraciones inseguras;
- aplicar hardening;
- reducir exposición de red;
- aplicar recomendaciones de seguridad sobre el workload.

Por tanto:

Mitigate = ataque actual

Prevent future attacks = postura de seguridad futura

1.1.3.8 Automated response

Desde:

Trigger automated response

puede ejecutarse:

Logic App

asociada a la alerta.
Esto permite automatizar respuestas como:

- notificaciones;
- creación de tickets;
- cambios sobre recursos;
- integración con herramientas externas.

1.1.3.9 Suppress similar alerts

Si la actividad es legítima y se espera que vuelva a producirse puede utilizarse:

Suppress similar alerts

para crear una:

suppression rule

en Defender for Cloud.
Debe utilizarse únicamente después de comprobar que la actividad:

no representa una amenaza real.

1.1.3.10 Sincronización de estado

Para alertas originadas realmente en Defender for Cloud:

los cambios de estado se sincronizan entre Defender for Cloud y Defender XDR

en ambos sentidos.
Sin embargo, existe una excepción importante:

Microsoft Defender for Endpoint alerts sobre cloud resources

pueden aparecer en ambos productos, pero su estado:

no se sincroniza entre Defender for Cloud y Defender XDR

como ocurre con una alerta nativa de Defender for Cloud.

1.1.3.11 Defender for Cloud + Sentinel

Si Microsoft Sentinel está integrado con Defender XDR, Microsoft recomienda actualmente utilizar:

Tenant-based Microsoft Defender for Cloud connector

para sincronizar las alertas de todo el tenant.

Debe evitarse mantener simultáneamente mecanismos antiguos que creen los mismos incidentes porque pueden producir:

duplicate alerts / incidents

En particular, debe evitarse duplicar la integración mediante:

- legacy subscription-based Defender for Cloud connector;
- antiguas analytics rules destinadas a recrear incidentes Defender for Cloud.

1.1.3.12 Escenarios típicos de examen

Escenario 1: una alerta indica ejecución de un proceso sospechoso dentro de un pod Kubernetes.

Advanced Hunting → `CloudProcessEvents`

Escenario 2: se quiere investigar una operación sospechosa realizada sobre Azure Resource Manager.

`CloudAuditEvents`

Escenario 3: se necesita comprobar actividad sospechosa sobre almacenamiento cloud.

`CloudStorageAggregatedEvents`

Escenario 4: Defender for Cloud muestra una amenaza y se necesitan los pasos concretos para eliminarla.

Take action → Mitigate the threat

Escenario 5: una amenaza ya se ha eliminado, pero se quiere evitar que vuelva a producirse.

Prevent future attacks / Security recommendations

Escenario 6: se necesita ejecutar automáticamente una respuesta externa.

Trigger automated response → Logic App

Escenario 7: una alerta Defender for Cloud no aparece en Defender XDR y su severidad es Informational.

Comportamiento esperado: Informational alerts no se integran.

1.1.4 Investigate and remediate security risks identified by Microsoft Defender for Cloud Apps

Microsoft Defender for Cloud Apps identifica riesgos relacionados con:

- actividad anómala de usuarios;
- aplicaciones cloud;
- aplicaciones OAuth;
- acceso y movimiento de datos;
- sesiones de usuario.

Sus alertas aparecen en:

Microsoft Defender portal → Incidents & alerts

y pueden correlacionarse con el resto de señales de Defender XDR.

1.1.4.1 Activity log

La herramienta principal para investigar actividad cloud es:

Cloud Apps → Activity log

Permite analizar:

- usuario;
- aplicación;
- actividad realizada;
- IP;
- ubicación;
- dispositivo;
- resultado de la actividad.

1.1.4.2 Investigación de una identidad

Desde:

Assets → Identities

puede revisarse el historial de actividad y las alertas asociadas a un usuario.

Cuando se confirma una actividad maliciosa, Defender for Cloud Apps dispone de acciones de gobierno como:

- **Suspend user**;
- **Require user to sign in again**;
- **Confirm user compromised**.

1.1.4.3 Require user to sign in again

Esta acción:

revoca refresh tokens y session cookies

y obliga al usuario a autenticarse nuevamente.
Es apropiada cuando:

se sospecha que una sesión ha sido comprometida.

1.1.4.4 Confirm user compromised

La acción:

Confirm user compromised

establece el nivel de riesgo del usuario como:

High

en Microsoft Entra ID.
Esto permite que las políticas de:

Microsoft Entra ID Protection / Conditional Access

respondan según el riesgo configurado.

1.1.4.5 CloudAppEvents

Para ampliar la investigación mediante Advanced Hunting puede utilizarse:

`CloudAppEvents`

Esta tabla contiene actividades procedentes de aplicaciones cloud conectadas y resulta útil para investigar:

- actividad de usuarios;
- actividad de aplicaciones;
- operaciones administrativas;
- acciones sobre archivos y datos.

Ejemplo:

```
CloudAppEvents
| where AccountDisplayName == "user"
| order by Timestamp desc
```

1.1.4.6 Cloud Discovery

Defender for Cloud Apps también permite identificar:

Shadow IT

mediante Cloud Discovery.
Una aplicación descubierta puede clasificarse como:

- **Sanctioned**;
- **Unsanctioned**.

Para SC-200:

Unsanctioned = aplicación cuyo uso la organización quiere impedir o desaconsejar

La información de riesgo del Cloud App Catalog ayuda a decidir si una aplicación debe permitirse.

1.1.4.7 Conditional Access App Control

Defender for Cloud Apps puede controlar sesiones en tiempo real mediante:

Conditional Access App Control

integrado con Microsoft Entra Conditional Access.
Permite aplicar:

- **access policies**;
- **session policies**.

1.1.4.8 Access policies

Las access policies permiten:

permitir o bloquear el acceso a una aplicación

según condiciones como:

- usuario;
- aplicación;
- dispositivo;
- ubicación;
- nivel de riesgo.

1.1.4.9 Session policies

Las session policies permiten controlar:

qué puede hacer un usuario dentro de una sesión ya iniciada.

Por ejemplo:

- bloquear descargas;
- bloquear uploads;
- bloquear malware;
- impedir copiar/imprimir información;
- monitorizar la sesión;
- proteger documentos al descargarlos.

Por tanto:

Access policy = controlar acceso

Session policy = controlar acciones dentro de la sesión

1.1.4.10 Escenarios típicos de examen

Escenario 1: un usuario realiza actividad sospechosa desde una ubicación desconocida.

Activity log + Identity page

Escenario 2: se sospecha que la sesión de un usuario ha sido robada.

Require user to sign in again

Escenario 3: se confirma que la identidad está comprometida.

Confirm user compromised

Escenario 4: una OAuth app solicita permisos excesivos y realiza actividad anómala.

App governance → investigar permisos/actividad → revoke/disable app

Escenario 5: se quiere impedir que usuarios descarguen documentos sensibles desde dispositivos no administrados.

Conditional Access App Control → Session policy

Escenario 6: se quiere bloquear completamente el acceso a una cloud app según el riesgo.

Access policy

1.1.5 Investigate and remediate compromised identities that are identified by Microsoft Entra ID

Microsoft Entra ID Protection detecta riesgo sobre identidades mediante dos conceptos:

Sign-in risk = probabilidad de que un inicio de sesión no sea legítimo

User risk = probabilidad de que la identidad esté comprometida

Los niveles de riesgo son:

Low / Medium / High

Para disponer de todas las capacidades de investigación y remediación se requiere normalmente:

Microsoft Entra ID P2

1.1.5.1 Investigación

Los principales informes están en:

Microsoft Entra admin center → ID Protection

y permiten revisar:

- **Risky users**;
- **Risky sign-ins**;
- **Risk detections**.

Durante la investigación debe comprobarse especialmente:

- aplicación;
- IP y geolocalización;
- dispositivo;
- user agent;
- autenticación utilizada;
- historial de inicios de sesión;
- detecciones de riesgo relacionadas.

Ejemplos de detecciones son:

- leaked credentials;
- atypical travel;
- anonymous/malicious IP;
- password spray;
- anomalous token.

1.1.5.2 Investigación en Defender XDR

Desde un risky user puede seleccionarse:

View full report in Microsoft Defender

o investigarse directamente desde:

Assets → Identities

1.1.5.3 Acciones sobre un risky user

Después de investigar pueden utilizarse:

Acción	**Cuándo utilizarla**
Confirm user compromised	Se confirma un true positive. Establece el user risk en High.
Confirm user safe	La detección es un false positive. Elimina el riesgo y permite reaprender el comportamiento del usuario.
Dismiss user risk	El riesgo era real pero benigno, por ejemplo una prueba autorizada.
Reset password	Se necesita corregir una identidad comprometida; también revoca las sesiones actuales.
Block user	Debe impedirse inmediatamente que la identidad siga autenticándose.

1.1.5.4 Confirm compromised

Si la investigación confirma el compromiso:

Confirm user compromised

provoca que Entra ID Protection:

- establezca el user risk en **High**;
- cree una detección **Admin confirmed user compromised**.

1.1.5.5 Remediación

Si se confirma un compromiso real, Microsoft recomienda acciones como:

- restablecer/cambiar la contraseña;
- revocar sesiones y tokens;
- bloquear temporalmente al usuario si es necesario;
- volver a registrar MFA cuando exista sospecha sobre sus métodos de autenticación;

- investigar persistencia y actividad posterior al compromiso.

Por tanto:

Confirm compromised

$$\neq$$

Remediate compromised account

1.1.5.6 Self-remediation mediante Conditional Access

Microsoft recomienda automatizar la respuesta mediante:

Risk-based Conditional Access

Para:

Sign-in risk

puede exigirse:

MFA

Si el usuario completa correctamente MFA, el risky sign-in puede quedar:

Remediated

Para:

User risk

puede exigirse:

- **Require risk remediation**;
- **Require password change**;
- **Block access**.

Así:

Sign-in risk → MFA

User risk → secure password/risk remediation

es una asociación muy importante para el examen.

1.1.5.7 Leaked credentials

La detección:

Leaked credentials

es especialmente crítica porque Microsoft la considera:

High risk

Si se confirma uso no autorizado:

Reset password + revoke sessions

y, si el atacante mantiene capacidad de autenticación:

Block user

hasta completar la remediación.

1.1.5.8 Escenarios típicos de examen

Escenario 1: un usuario inicia sesión desde una IP anómala, pero confirma que estaba conectado a la VPN corporativa autorizada.

Confirm user safe

Escenario 2: una prueba de penetración autorizada genera una detección real de riesgo.

Dismiss user risk

Escenario 3: se confirma que unas credenciales filtradas han sido utilizadas por un atacante.

Confirm compromised → Reset password + Revoke sessions

Escenario 4: se quiere corregir automáticamente un risky sign-in.

Risk-based Conditional Access → Require MFA

Escenario 5: un usuario alcanza High user risk.

Conditional Access → Require risk remediation/password change o Block access

1.1.6 Investigate and remediate security alerts from Microsoft Defender for Identity

Microsoft Defender for Identity detecta actividad sospechosa relacionada con identidades y Active Directory, especialmente:

- Credential Access;
- Discovery;
- Lateral Movement;
- Persistence;
- Privilege Escalation.

Sus alertas se investigan desde:

Microsoft Defender portal → Incidents & alerts → Alerts

filtrando por:

Detection source = Microsoft Defender for Identity

1.1.6.1 Alert story

Al abrir una alerta debe revisarse:

Alert story

que muestra cronológicamente:

- actividad detectada;
- cuenta involucrada;
- source host;
- destination host;
- eventos anteriores y posteriores;
- otras entidades relacionadas.

Para SC-200:

Alert story = qué ocurrió + cuándo + entre qué entidades

1.1.6.2 Identity page

La entidad más importante suele ser la identidad afectada.
Ruta:

Assets → Identities

Alert → Identity page → investigar contexto y alcance

1.1.6.3 Lateral movement

Una capacidad especialmente importante de Defender for Identity es identificar:

Lateral Movement Paths

que muestran cómo un atacante podría utilizar cuentas y dispositivos comprometidos para alcanzar recursos más sensibles.

Por ejemplo:

Compromised workstation

⇓

User credentials

⇓

Privileged server

⇓

Domain Admin / sensitive asset

1.1.6.4 Alertas típicas

No es necesario memorizar todas las alertas, pero sí reconocer patrones como:

- Pass-the-Hash;
- Pass-the-Ticket;
- suspicious NTLM/SMB authentication;
- account enumeration;
- credential theft;
- suspicious modifications to accounts/groups;
- shadow credentials;
- suspicious Active Directory ACL changes.

La lógica para el examen es:

Actividad de identidad on-premises / AD → Defender for Identity

1.1.6.5 Respuesta sobre identidades

Las acciones disponibles dependen del sistema que administra la cuenta.
Desde:

Identity page → Actions

pueden aparecer acciones como:

- **Disable**;
- **Enable**;
- **Revoke session**;
- **Mark as compromised**;
- **Force password change**.

1.1.6.6 Disable

Disable

deshabilita la cuenta afectada e impide:

- autenticación;
- acceso a recursos;
- continuación del movimiento lateral.

Para cuentas on-premises Active Directory, la acción la ejecuta:

Defender for Identity sensor en un Domain Controller

1.1.6.7 Force password change

Force password change

obliga al usuario a cambiar la contraseña en el siguiente inicio de sesión.
Es apropiado cuando:

las credenciales pueden haber sido comprometidas

pero la cuenta puede seguir utilizándose después de corregirla.

1.1.6.8 Revoke session

Para identidades compatibles puede utilizarse:

Revoke session

para finalizar las sesiones activas.
Esto es especialmente útil cuando:

el atacante puede disponer de tokens/sesiones válidas

aunque ya se haya cambiado la contraseña.

1.1.6.9 Mark as compromised

Para identidades Entra vinculadas:

Mark as compromised

marca la identidad como comprometida y permite que otros controles de identidad respondan al riesgo.

No debe confundirse con:

deshabilitar la cuenta

o:

cambiar su contraseña.

1.1.6.10 Action accounts

Para que Defender for Identity pueda ejecutar acciones sobre cuentas de Active Directory, debe estar correctamente configurado el mecanismo de:

Action accounts

En configuraciones actuales Microsoft recomienda:

Automatically use the sensor's local system account

desde:

Settings → Identities → Microsoft Defender for Identity → Manage action accounts

Los sensores instalados en:

Domain Controllers

son los que ejecutan las acciones sobre Active Directory.

1.1.6.11 Action Center

Las acciones ejecutadas pueden revisarse en:

Actions & submissions → Action Center

1.1.6.12 Advanced Hunting

La investigación puede ampliarse mediante Advanced Hunting.

Para actividad de identidad son especialmente relevantes tablas como:

`IdentityLogonEvents` → autenticaciones

`IdentityQueryEvents` → consultas a Active Directory

`IdentityDirectoryEvents` → cambios en directorio

Estas tablas permiten determinar:

- desde qué host se autenticó una cuenta;
- qué recursos consultó;
- qué cambios realizó;
- si existe movimiento lateral.

1.1.6.13 Escenarios típicos de examen

Escenario 1: Defender for Identity detecta un Pass-the-Ticket entre dos sistemas.

> **Revisar Alert story + source/destination hosts + Identity page**

Escenario 2: una identidad comprometida dispone de acceso hacia una cuenta privilegiada.

> **Revisar Attack paths / lateral movement paths**

Escenario 3: se confirma que las credenciales de una cuenta AD han sido robadas.

> **Disable o Force password change**

según la gravedad y necesidad operativa.
Escenario 4: se quiere comprobar qué autenticaciones realizó posteriormente la cuenta.

> **Advanced Hunting** → `IdentityLogonEvents`

Escenario 5: una acción Disable sobre una cuenta AD no puede ejecutarse.

> **Comprobar Manage action accounts y los sensores de Domain Controller**

investigación, no todas las operaciones realizadas en Active Directory.

1.1.7 Investigate and remediate alerts and incidents identified by Microsoft Sentinel

Los incidentes generados por Microsoft Sentinel se investigan actualmente desde:

> **Investigation & response → Incidents & alerts → Incidents**

en el Microsoft Defender portal.

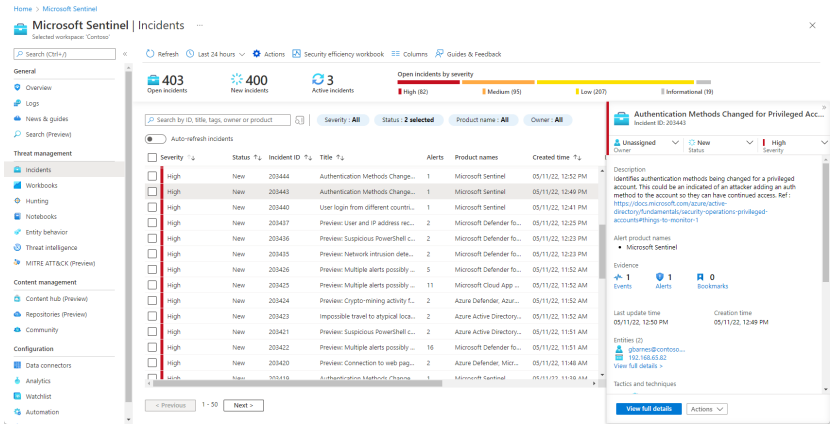


Figure 2: Caption

La experiencia recomendada actualmente son los:

Incident cases

que agrupan:

- alerts;
- affected assets/entities;
- evidence;
- investigations;
- activities;
- tasks y comentarios.

1.1.7.1 Flujo de investigación

Para SC-200 puede seguirse:

Triage → Investigate → Contain/Remediate → Resolve

1.1.7.2 Attack story

La:

Attack story

permite reconstruir visualmente la secuencia del ataque y las relaciones entre:

- alerts;
- users;
- devices;
- mailboxes;
- applications;
- cloud resources;
- otras entidades.

Debe utilizarse para determinar:

alcance + secuencia + activos afectados

antes de iniciar la remediación.

1.1.7.3 Assets y entity pages

La sección:

Assets

muestra las entidades relacionadas con el incidente.
Al seleccionar una entidad puede revisarse información como:

- alertas relacionadas;
- risk/exposure;
- actividad;
- timeline;
- metadata;
- insights.

1.1.7.4 Timeline

La:

Timeline

permite analizar cronológicamente:

- alertas;
- actividades;
- eventos relacionados con la entidad.

Es especialmente útil para determinar si:

una actividad sospechosa es aislada o forma parte de un ataque mayor.

1.1.7.5 Top insights

Sentinel puede mostrar:

> **Top insights**

generados mediante consultas predefinidas.
Entre otros, pueden incluir:

- threat indicators relacionados;
- actividad de inicio de sesión;
- conexiones IP;
- actividad anómala;
- watchlist matches.

Desde un insight puede abrirse:

> **la consulta KQL que lo produjo**

para continuar la investigación.

1.1.7.6 Logs y Advanced Hunting

Si la información del incidente no es suficiente debe ampliarse mediante:

> **Advanced Hunting / Logs**

Con Sentinel integrado en Defender, los datos del Log Analytics workspace pueden consultarse desde:

> **Investigation & response → Hunting → Advanced hunting**

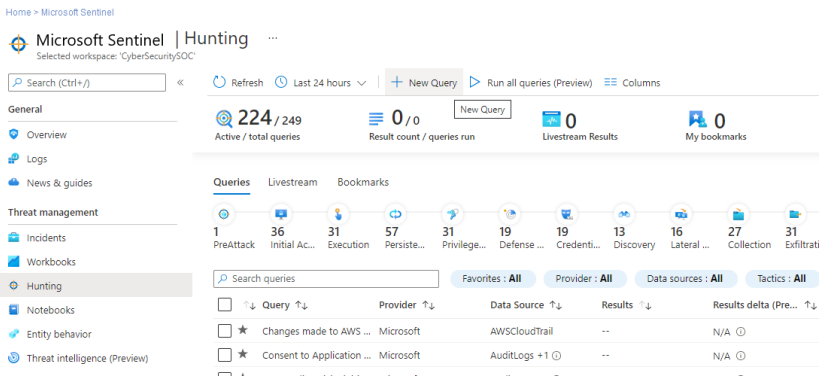


Figure 3: Caption

1.1.7.7 Similar incidents

Sentinel/Defender permite consultar:

Similar incidents

para localizar incidentes que comparten características con el incidente actual.

1.1.7.8 Tasks

Los:

Incident tasks

permiten estandarizar el procedimiento seguido por el SOC.

1.1.7.9 Investigation graph

En la experiencia de Microsoft Sentinel del Azure portal también existe el:

Investigation graph

que representa visualmente:

- alerts;
- entities;
- relaciones;
- timeline.

Permite utilizar:

exploration queries

para ampliar el grafo buscando entidades o alertas relacionadas.
Esta capacidad depende de que las analytics rules hayan realizado correctamente:

Entity mapping

Aunque Sentinel está migrando al Defender portal, conviene reconocer este concepto para SC-200.

1.1.7.10 Escenarios típicos de examen

Escenario 1: se necesita comprender rápidamente la secuencia completa de un ataque y los activos relacionados.

Attack story

Escenario 2: se quiere conocer toda la actividad de un usuario antes y después de la alerta.

Entity page → Timeline

Escenario 3: se necesitan buscar eventos adicionales que no forman parte del incidente.

Advanced Hunting / Logs

Escenario 4: una alerta se correlacionó con el incidente incorrecto.

Move alert

Escenario 5: dos incidentes corresponden al mismo ataque.

Merge incident cases

Escenario 6: se quiere asegurar que todos los analistas siguen el mismo procedimiento de respuesta.

Incident tasks

Escenario 7: la investigación y remediación han finalizado.

Resolve + Classification + Resolution notes

1.1.8 Investigate incidents by using agentic AI, including embedded Microsoft Security Copilot

Microsoft Defender incorpora capacidades de:

Microsoft Security Copilot + AI Agents

para acelerar el triage, investigación y respuesta a incidentes de Microsoft Defender XDR y Microsoft Sentinel.

Para SC-200 deben distinguirse:

Capacidad	Función
Embedded Security Copilot	Asiste interactivamente al analista durante la investigación.
Security Copilot agents	Ejecutan tareas de seguridad de forma autónoma o semiautónoma según sus triggers, herramientas y permisos.

1.1.8.1 Embedded Security Copilot

Security Copilot está integrado directamente en:

Microsoft Defender portal

y mantiene el contexto de la página que está visualizando el analista.

1.1.8.2 Incident summary

Al abrir un incidente, Copilot puede generar:

Incident summary

que resume información como:

- qué ocurrió;
- timeline;
- alerts relacionadas;
- usuarios y dispositivos afectados;
- IOC;
- alcance del ataque.

1.1.8.3 Análisis de scripts y command lines

Desde el attack story o device timeline, Copilot puede analizar:

scripts y command lines

incluyendo PowerShell u otros scripts potencialmente ofuscados.
Copilot puede:

- explicar qué hace el script;
- identificar comportamiento sospechoso;
- extraer IOC;
- proporcionar contexto de amenaza.

Por tanto:

PowerShell ofuscado difícil de interpretar

$\Rightarrow$

Analyze with Security Copilot

1.1.8.4 Agentic AI

Un agente de Security Copilot va más allá de responder a un prompt.
Puede:

reason → plan → use tools → produce/execute outcome

según:

- trigger configurado;
- identidad del agente;
- permisos asignados;
- herramientas/plugins disponibles.

Los agentes relevantes para operaciones SOC incluyen:

- **Security Alert Triage Agent**;
- **Security Analyst Agent**;
- **Dynamic Threat Detection Agent**;
- Threat Hunting Assistant;
- Threat Intelligence Briefing Agent.

1.1.8.5 Security Alert Triage Agent

El más importante para este objetivo es:

Security Alert Triage Agent

que ejecuta automáticamente el triage de alertas compatibles.
Su trigger es:

creación de una nueva alerta compatible

El agente analiza automáticamente la evidencia y determina si la alerta representa:

True Positive

o:

False Positive

Si determina:

False Positive

puede clasificar y resolver la alerta.
Si determina:

True Positive

la clasifica como tal y mantiene el incidente:

open/in progress para investigación del analista

Por tanto:

Security Alert Triage Agent = autonomous alert triage

no sustituye completamente la investigación y remediación del incidente.

1.1.8.6 Transparent reasoning

El agente proporciona:

- verdict;
- evidencia utilizada;
- explicación en lenguaje natural;
- representación gráfica del workflow seguido.

Desde la tarjeta del agente puede seleccionarse:

View agent activity

para revisar cómo llegó a su clasificación.
El analista puede proporcionar feedback sobre el resultado para mejorar futuras clasificaciones en los escenarios compatibles.

Security Analyst Agent = investigación/análisis solicitado por el analista

Security Alert Triage Agent = triage automático al llegar una alerta

1.1.8.7 Security Store

Los agentes pueden descubrirse y desplegarse desde:

Security Copilot → Security Store

y administrarse posteriormente desde:

Security Copilot → Agents

Para utilizar agentes se necesita acceso a un:

Security Copilot workspace con SCU capacity

además de las licencias y permisos específicos del agente.

1.1.8.8 Human in the loop

Aunque se utilice AI agentic:

el analista sigue siendo responsable de validar el resultado

Los modelos pueden producir resultados incorrectos o incompletos.

1.1.8.9 Escenarios típicos de examen

Escenario 1: un incidente contiene muchas alertas y se necesita comprender rápidamente qué ocurrió.

Security Copilot → Incident summary

Escenario 2: se necesitan recomendaciones específicas para contener y remediar un incidente.

Guided responses

Escenario 3: aparece una línea PowerShell ofuscada.

Security Copilot → Script analysis

Escenario 4: se quiere clasificar automáticamente gran volumen de nuevas alertas.

Security Alert Triage Agent

Escenario 5: se necesita realizar un análisis complejo sobre datos Defender y Sentinel utilizando lenguaje natural.

Security Analyst Agent

Escenario 6: se quieren descubrir amenazas que las detecciones tradicionales podrían haber omitido.

Dynamic Threat Detection Agent

Escenario 7: Copilot recomienda aislar un dispositivo.

Revisar recomendación → ejecutar acción si procede y se dispone de permisos

1.1.9 Investigate complex attacks, such as multi-stage, multi-domain, and lateral movement

Microsoft Defender XDR correlaciona alertas de distintos productos dentro de un mismo incidente para reconstruir ataques complejos.

1.1.9.1 Tipos de ataques complejos

- **Multi-stage**: el ataque atraviesa varias fases, por ejemplo Initial Access → Credential Access → Lateral Movement → Exfiltration.
- **Multi-domain**: afecta a distintos dominios de seguridad, por ejemplo email, identidad, endpoint y cloud.
- **Lateral movement**: el atacante utiliza una identidad o sistema comprometido para acceder a otros recursos.

Ejemplo:

> Phishing email → stolen credentials → compromised device → lateral movement → privileged account

1.1.9.2 Attack story

La herramienta principal para investigar estos ataques es:

> **Attack story / Incident graph**

Permite visualizar:

- dónde comenzó el ataque;
- cómo progresó;
- qué alertas están relacionadas;
- qué usuarios, dispositivos, mailboxes y cloud resources están afectados;
- hasta dónde consiguió avanzar el atacante.

La reproducción temporal del grafo permite reconstruir:

> **la secuencia cronológica del ataque**

1.1.9.3 Flujo de investigación

En un ataque complejo debe identificarse:

1. **Initial access**: punto inicial de compromiso.
2. **Compromised entities**: usuarios, dispositivos, mailboxes o recursos.
3. **Credential access**: credenciales o sesiones comprometidas.
4. **Lateral movement**: recursos a los que accedió posteriormente el atacante.
5. **Privilege escalation**: acceso a identidades o activos más privilegiados.
6. **Impact/Objective**: objetivo final alcanzado o intentado.

1.1.9.4 Multi-domain investigation

Defender XDR correlaciona señales de diferentes workloads.

Por ejemplo:

Defender for Office 365

⇓

Microsoft Entra ID / Defender for Identity

⇓

Defender for Endpoint

⇓

Defender for Cloud / Cloud Apps

El objetivo es:

investigar el incidente completo y no cada alerta de forma aislada

1.1.9.5 Escenarios típicos de examen

Escenario 1: existen alertas de phishing, inicio de sesión sospechoso y malware en un endpoint.

Investigar como un único incidente mediante Attack story

Escenario 2: se quiere saber cómo una cuenta comprometida puede alcanzar Domain Admin.

Identity page → Attack paths

Escenario 3: se necesita identificar desde qué equipo una cuenta comprometida accedió posteriormente a otros sistemas.

Advanced Hunting → IdentityLogonEvents / DeviceLogonEvents

1.1.10 Manage security incidents by using case management

Microsoft Defender incorpora:

Case management

para gestionar el trabajo del SOC directamente desde el Defender portal.
Un:

Incident case

agrupa el incidente junto con:

- alerts y contexto de investigación;
- evidence;
- tasks;
- comments;
- attachments;
- activity history;
- workflow y ownership.

Los:

Incident cases están actualmente en Preview y son la experiencia recomendada

frente a la experiencia legacy de incidentes.

1.1.10.1 Case types

Case management distingue:

Tipo	Uso
Incident case	Gestionar y resolver un incidente de seguridad correlacionado.
Generic case	Registrar trabajo SecOps no necesariamente asociado a un incidente.

Para este objetivo de SC-200 interesa principalmente:

Incident case

1.1.10.2 Propiedades del case

Desde:

Microsoft Defender portal → Cases

pueden gestionarse propiedades como:

- **Priority**;
- **Status**;
- **Assigned to**;
- Tags;
- Description;
- SLA policy.

El objetivo es establecer claramente:

prioridad + propietario + estado + seguimiento

1.1.10.3 Priority y ownership

La prioridad permite determinar qué casos deben atenderse primero.
El:

Assignee

establece quién es responsable del caso.

1.1.10.4 Tasks

Un case puede dividirse en:

Tasks

para asignar acciones concretas a miembros del SOC.
Cada task puede incluir:

- owner;
- priority;
- status;
- due date;
- description;
- closing notes.

Por tanto:

Case = investigación completa

mientras que:

Task = acción concreta dentro de esa investigación

1.1.10.5 Attachments

Los casos admiten:

Attachments

para almacenar evidencia o documentación relacionada con la investigación.

1.1.10.6 Merge incident cases

Si dos cases corresponden realmente al mismo ataque:

Merge incident cases

permite consolidarlos.

1.1.10.7 Move alerts

Si una alerta está asociada al case incorrecto debe utilizarse:

Move alert

para trasladarla a otro incident case.

1.1.10.8 Auditoría mediante KQL

Cuando existe un Microsoft Sentinel workspace primario conectado, la actividad de Case Management se sincroniza con:

`SecurityCaseEvent`

en Log Analytics.

1.1.10.9 Permisos

Para Incident cases:

Permiso Unified RBAC	**Capacidad**
Security Data Read	Ver e investigar incident cases.
Security Data Manage	Ver, investigar y administrar incident cases.

1.1.10.10 Escenarios típicos de examen

Escenario 1: varias alertas e investigaciones corresponden al mismo ataque.

Merge incident cases

Escenario 2: una alerta se correlacionó con el case equivocado.

Move alert

Escenario 3: se quiere asignar distintas acciones de investigación a varios analistas.

Tasks

Escenario 4: se quiere conocer quién cambió el estado o assignment de un case.

Activity history

Escenario 5: se quiere consultar mediante KQL el historial de Case Management.

```
SecurityCaseEvent
```

1.2 Respond to alerts and incidents in Microsoft Defender for Endpoint

1.2.1 Investigate device timelines

La:

Device timeline

muestra cronológicamente todos los eventos y alertas observados en un dispositivo.

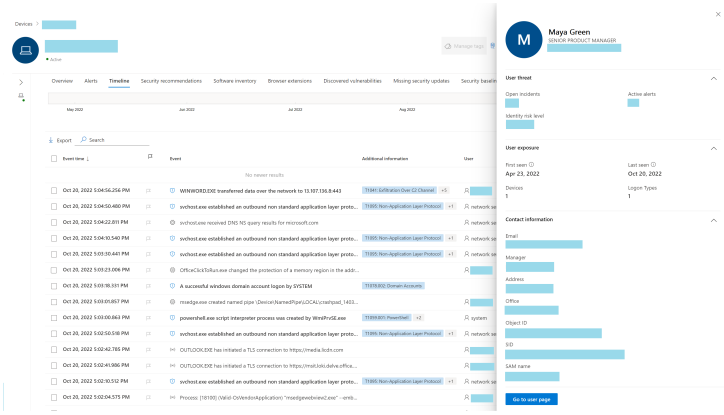


Figure 4: Caption

Se accede desde:

Assets → Devices → Device → Timeline

o directamente desde un dispositivo afectado dentro de una alerta o incidente.

1.2.1.1 Qué investigar

La timeline permite reconstruir qué ocurrió antes, durante y después de una actividad sospechosa.

Entre los eventos más relevantes están:

- creación y ejecución de procesos;
- command lines y scripts;
- conexiones de red;
- logons;
- modificaciones de archivos;
- cambios de registro;

- detecciones de malware;
- acciones de remediación.

Para SC-200:

Device timeline = reconstrucción cronológica de la actividad del endpoint

1.2.1.2 Process tree

Al seleccionar determinados eventos puede mostrarse el:

Process tree

que permite analizar relaciones:

Parent process → Child process

Por ejemplo:

`winword.exe` → `powershell.exe` → `cmd.exe`

1.2.1.3 Filtros

La timeline puede filtrarse por:

- rango temporal;
- tipo de evento;
- texto/búsqueda;
- eventos marcados.

Por defecto muestra aproximadamente:

los últimos 30 días

1.2.1.4 Hunt for related events

Desde un evento puede utilizarse:

Hunt for related events

para abrir Advanced Hunting con una consulta que busca:

- el evento seleccionado;
- otros eventos relacionados;
- actividad ocurrida aproximadamente en el mismo momento y dispositivo.

Por tanto:

Timeline → evento sospechoso → Hunt for related events

es el flujo para ampliar la investigación mediante hunting.

1.2.1.5 Escenarios típicos de examen

Escenario 1: se necesita conocer qué ocurrió inmediatamente antes de ejecutar un proceso malicioso.

Device timeline

Escenario 2: se quiere identificar qué proceso lanzó PowerShell.

Process tree

Escenario 3: se necesita buscar actividad adicional relacionada con un evento concreto.

Hunt for related events

Escenario 4: durante una investigación se quieren conservar únicamente varios eventos especialmente relevantes.

Flag events

1.2.2 Perform actions on the device, including live response and collecting investigation packages

Desde la página de un dispositivo:

Assets → Devices → Device

Microsoft Defender for Endpoint permite ejecutar acciones de respuesta directamente sobre el endpoint.

1.2.2.1 Principales device actions

Las más relevantes para SC-200 son:

Acción	Objetivo
Isolate device	Aísla el dispositivo de la red manteniendo comunicación con Defender for Endpoint.
Run antivirus scan	Ejecuta un análisis Quick o Full con Microsoft Defender Antivirus.
Restrict app execution	Impide ejecutar aplicaciones que no estén firmadas por Microsoft.
Collect investigation package	Recopila información forense del dispositivo.
Initiate Live Response Session	Abre una shell remota para investigar y responder directamente sobre el equipo.

1.2.2.2 Live Response

Live Response = remote interactive shell sobre el endpoint

Se utiliza cuando el analista necesita investigar o actuar directamente sobre un dispositivo.

1.2.2.3 Live Response library

Para ejecutar un script mediante:

```
run script.ps1
```

el script debe estar previamente cargado en la:

Live Response library

También puede utilizarse:

```
putfile
```

para enviar un archivo de la library al dispositivo.
Por tanto:

Library → putfile/run → endpoint

1.2.2.4 Investigation package

La acción:

Collect investigation package

recopila información forense para conocer:

- estado actual del dispositivo;
- procesos;
- persistencia;
- programas instalados;
- conexiones de red;
- otra información útil para reconstruir la actividad del atacante.

En Windows incluye, entre otros:

Autoruns + Installed programs + Network connections

Una vez finalizada la recopilación, el paquete puede descargarse como:

ZIP

desde la página del dispositivo o:

Action Center

1.2.2.5 Action Center

Las acciones ejecutadas sobre dispositivos pueden revisarse en:

Action Center

donde se muestra su:

- estado;
- usuario que la ejecutó;
- fecha/hora;
- resultado.

1.2.2.6 Escenarios típicos de examen

Escenario 1: se necesita impedir inmediatamente que un equipo comprometido se comunique con otros sistemas.

Isolate device

Escenario 2: se necesita inspeccionar remotamente procesos, conexiones y archivos de un dispositivo.

Live Response

Escenario 3: se necesita ejecutar un PowerShell de investigación sobre el endpoint.

Upload to Live Response library → run

Escenario 4: se necesita recopilar información forense para analizar posteriormente el compromiso.

Collect investigation package

1.2.3 Perform evidence and entity investigation

En Defender for Endpoint, la pestaña:

Evidence and response

agrupa las evidencias y entidades relacionadas con un incidente para determinar:

qué elemento es malicioso, qué activos afecta y si ya ha sido remediado.

1.2.3.1 Evidence

Entre las evidencias pueden aparecer:

- files;
- processes;
- services;
- IP addresses;
- URLs;
- users;
- devices.

Para cada evidencia deben revisarse principalmente:

- **Verdict**;
- **Remediation status**;
- activos afectados;
- amenazas asociadas;
- origen de la detección.

Los verdicts relevantes son:

Malicious / Suspicious / Clean o No threats found

1.2.3.2 Entity investigation

Al seleccionar una entidad puede abrirse su:

Entity page

para obtener contexto adicional.
Por ejemplo:

- **File**: hash, prevalence, signer, detecciones y dispositivos donde apareció.
- **IP/URL/domain**: reputación, infraestructura y threat intelligence.
- **Device**: timeline, alerts y actividad relacionada.
- **User**: alertas, actividad y dispositivos asociados.

El flujo recomendado es:

Evidence → Entity page → related activity/entities

para ampliar progresivamente el alcance de la investigación.

1.2.3.3 Advanced Hunting

La tabla:

`AlertEvidence`

contiene las entidades asociadas a las alertas.
Puede combinarse con:

`AlertInfo`

mediante:

`AlertId`

para investigar simultáneamente:

alert metadata + related evidence/entities

1.2.3.4 Escenarios típicos de examen

Escenario 1: se quiere conocer si un archivo detectado es realmente malicioso y en qué dispositivos apareció.

File entity page

Escenario 2: se necesita comprobar reputación y relaciones de una IP sospechosa.

IP entity → Threat Intelligence Insights

Escenario 3: se necesitan obtener mediante KQL todas las entidades relacionadas con una alerta.

`AlertEvidence`

1.2.4 Investigate and remediate incidents identified by automatic attack disruption

Cuando Automatic Attack Disruption interviene sobre un ataque, el incidente queda claramente identificado mediante:

- tag **Attack Disruption**;
- tipo de amenaza detectada, por ejemplo ransomware;
- banner indicando que el ataque ha sido interrumpido;
- etiquetas sobre los assets contenidos.

1.2.4.1 Attack disruption summary

En el incidente aparece una:

Attack disruption summary card

que resume:

- acciones automáticas ejecutadas;
- assets afectados;
- estado de las acciones.

Desde ella pueden utilizarse:

View activities

para revisar las acciones realizadas, y:

View related assets

para identificar usuarios, dispositivos, mailboxes o aplicaciones sobre los que actuó Defender.

1.2.4.2 Investigar el incidente

El analista debe revisar:

1. **Attack story**: cómo comenzó y progresó el ataque.
2. **Contained assets**: qué identidades o dispositivos fueron contenidos.
3. **Triggering alerts**: qué señales provocaron la disrupción.
4. **Remaining activity**: si existe actividad maliciosa no contenida.

Una acción automática de contención:

no implica que el incidente esté completamente remediado

Su objetivo principal es detener el avance del atacante y dar tiempo al SOC para completar la investigación.

1.2.4.3 Activities

La pestaña:

Activities

permite consultar las acciones de Attack Disruption asociadas al incidente, incluyendo:

- fecha/hora;

- alerta que desencadenó la acción;
- entidad afectada;
- acción ejecutada;
- estado actual.

El campo:

Policy status

permite comprobar si una acción sigue:

- activa;
- finalizada;
- expirada;
- revertida.

1.2.4.4 Action Center

Todas las acciones automáticas pueden revisarse en:

Actions & submissions → Action Center

Desde allí puede comprobarse:

- acción realizada;
- asset afectado;
- estado;
- origen automático de la acción.

1.2.4.5 Liberar assets contenidos

Una vez que:

- la investigación ha terminado;
- la amenaza ha sido eliminada;
- el asset ya es seguro;

puede revertirse la contención.
Por ejemplo:

Contained device → Release from containment

Suspended/disabled user → Enable user

También puede hacerse desde el Action Center.
Debe memorizarse:

Nunca liberar un asset antes de completar investigación y mitigación

porque el atacante podría recuperar su capacidad de actuación.

1.2.4.6 Escenarios típicos de examen

Escenario 1: se quiere identificar rápidamente qué acciones ejecutó Automatic Attack Disruption.

Attack disruption summary card

Escenario 2: se quiere comprobar el estado actual de las acciones automáticas.

Activities / Action Center

Escenario 3: un dispositivo fue contenido automáticamente y ya se ha confirmado que es seguro.

Release from containment

Escenario 4: una cuenta fue suspendida durante la disrupción y ya se ha completado la remediación.

Enable user

1.3 Investigate Microsoft 365 activities to identify threats

1.3.1 Investigate threats by using Microsoft Purview Audit

Microsoft Purview Audit permite investigar actividad histórica de usuarios y administradores en servicios de Microsoft 365 mediante el:

Unified Audit Log

Incluye actividad procedente de servicios como:

- Exchange Online;
- SharePoint;
- OneDrive;
- Microsoft Entra ID;
- Teams;
- Microsoft Purview.

Se accede desde:

Microsoft Purview portal → Audit → Search

1.3.1.1 Audit search

Los filtros más importantes son:

- **Date and time range**;
- **Activities**;
- **Users**;
- **Record types**;
- **Workloads**;
- **File, folder or site**;
- keywords.

Los timestamps se muestran en:

UTC

y una búsqueda individual permite seleccionar un intervalo máximo de:

180 días

1.3.1.2 Resultados

Los resultados muestran principalmente:

- Date;
- **IP Address**;
- **User**;
- Record type;
- **Activity**;
- Item;
- Details.

Para una investigación de compromiso son especialmente importantes:

User + Activity + IP Address + Timestamp

porque permiten reconstruir qué hizo una cuenta y desde dónde.

1.3.1.3 Actividades especialmente relevantes

No es necesario memorizar todas las operaciones del Unified Audit Log. Para SC-200 conviene reconocer:

Operación	Uso en investigación
`MailItemsAccessed`	Determinar qué mensajes fueron accedidos en un buzón comprometido.
`New-InboxRule` / `Set-InboxRule`	Detectar reglas de buzón creadas o modificadas por un atacante.
`Set-Mailbox`	Investigar cambios como forwarding de correo.
`SendAs`	Identificar envío de mensajes utilizando otra identidad/buzón.
`SoftDelete` / `HardDelete`	Investigar eliminación de mensajes.

1.3.1.4 MailItemsAccessed

La operación:

`MailItemsAccessed`

es especialmente importante para investigaciones forenses de cuentas Exchange comprometidas.

Permite conocer accesos al contenido del buzón y distingue principalmente:

- **Bind**: acceso a mensajes individuales;

- **Sync**: sincronización de una carpeta/conjunto de mensajes.

Para diferenciar actividad legítima de la del atacante son especialmente útiles propiedades como:

- `ClientIPAddress`;
- `ClientInfoString`;
- `SessionId`;
- `UserId`.

1.3.1.5 Exportar resultados

Los resultados pueden exportarse a:

CSV

para análisis forense o documentación.
El CSV contiene una propiedad:

`AuditData`

con detalles adicionales del evento.

1.3.1.6 Retención

Como referencia:

Audit Standard = 180 días por defecto

Audit Premium proporciona mayor retención; para usuarios correctamente licenciados, los registros de Exchange, SharePoint, OneDrive y Entra pueden conservarse:

1 año por defecto

y pueden configurarse políticas de retención superiores según licencia.

1.3.1.7 Escenarios típicos de examen

Escenario 1: se sospecha que un atacante leyó mensajes del buzón de un usuario.

`MailItemsAccessed`

Escenario 2: el correo de una víctima está siendo reenviado automáticamente al atacante.

`Set-Mailbox` + **Inbox Rule activities**

Escenario 3: se quiere identificar quién creó una regla de bandeja de entrada maliciosa.

`New-InboxRule` / `Set-InboxRule`

Escenario 4: se necesita analizar fuera del portal una gran cantidad de evidencias.

Export results → CSV

1.3.2 Investigate threats by using Content search in Microsoft Purview eDiscovery

Microsoft Purview eDiscovery permite buscar directamente contenido almacenado en Microsoft 365 para investigar incidentes como:

- cuentas comprometidas;
- exfiltración de información;
- phishing interno;
- mensajes o documentos sospechosos.

La búsqueda se realiza actualmente dentro de un:

eDiscovery case

en:

Microsoft Purview → eDiscovery → Cases → Searches

1.3.2.1 Content locations

eDiscovery puede buscar contenido en:

- **Exchange Online mailboxes**;
- **SharePoint Online**;
- **OneDrive**;
- **Microsoft Teams**;
- Microsoft 365 Groups;
- Viva Engage.

Por ejemplo, para investigar una cuenta comprometida puede buscarse correo enviado o recibido por ese usuario durante el periodo del ataque.

1.3.2.2 Crear una búsqueda

La búsqueda se construye principalmente mediante:

- keywords;
- sender/recipient;
- date;
- subject;
- content type;

- file properties;
- locations/users.

Puede utilizarse el:

Condition builder

o crear consultas más complejas mediante:

KeyQL – Keyword Query Language

Ejemplo conceptual:

```
(phishing OR password)
AND From:"[attacker@contoso.com](mailto:attacker@contoso.com)"
```

1.3.2.3 Operadores

Los operadores más importantes son:

AND / OR / NOT / NEAR

Las comillas permiten buscar frases exactas:

```
"confidential project"
```

Para el examen:

eDiscovery Search usa KeyQL, no KQL de Sentinel

1.3.2.4 Review search results

Después de ejecutar la búsqueda pueden revisarse:

- número de elementos encontrados;
- ubicaciones que contienen resultados;
- tamaño de los resultados;
- estadísticas por keyword.

Esto permite refinar progresivamente la consulta antes de recopilar grandes cantidades de información.

1.3.2.5 Review set

Cuando los resultados son relevantes pueden añadirse a un:

Review set

El contenido se copia desde su ubicación original a un repositorio seguro de eDiscovery para:

- analizarlo;
- filtrarlo;
- etiquetarlo;
- revisar mensajes y documentos;
- aplicar analytics.

Conceptualmente:

Search → identificar contenido

Review set → analizar contenido recopilado

1.3.2.6 Export

Los resultados de búsqueda o el contenido de un review set pueden:

Export

para análisis forense externo o conservación de evidencias.
eDiscovery distingue entre:

- elementos indexados que coinciden con la consulta;
- elementos parcialmente indexados o no indexados.

Los elementos parcialmente indexados pueden requerir revisión adicional porque:

el motor de búsqueda no puede evaluar completamente su contenido.

1.3.2.7 Escenarios típicos de examen

Escenario 1: se quiere encontrar todos los emails enviados por una cuenta comprometida durante un intervalo concreto.

eDiscovery Search → mailbox + sender + date

Escenario 2: se quieren localizar documentos que contienen determinadas palabras clave en SharePoint y OneDrive.

eDiscovery Search → keywords + SharePoint/OneDrive locations

Escenario 3: se han encontrado elementos relevantes y se necesita analizarlos detalladamente.

Add to review set

Escenario 4: se necesita extraer la evidencia para análisis fuera de Microsoft Purview.

Export

1.3.3 Investigate threats by using Microsoft Graph activity logs

Microsoft Graph activity logs proporcionan un:

audit trail de las peticiones HTTP recibidas por Microsoft Graph

para los recursos del tenant.
Permiten investigar actividad realizada mediante:

- usuarios;
- aplicaciones OAuth;
- service principals;
- SDK/API clients;
- aplicaciones Microsoft como Outlook o Teams.

1.3.3.1 Configuración

Los logs deben habilitarse mediante:

Diagnostic settings

y pueden enviarse a:

- **Log Analytics workspace**;
- Azure Storage;
- Event Hubs.

Para investigación con Microsoft Sentinel:

Diagnostic settings → Log Analytics workspace

1.3.3.2 Tabla principal

En Log Analytics/Sentinel los eventos se almacenan en:

`MicrosoftGraphActivityLogs`

Ejemplo:

```
MicrosoftGraphActivityLogs
| where TimeGenerated > ago(24h)
| project TimeGenerated, UserId, AppId,
IPAddress, RequestMethod,
RequestUri, ResponseStatusCode
```

1.3.3.3 Campos más importantes

Para SC-200 conviene conocer:

Campo	Uso
`UserId`	Usuario que realizó la petición.
`AppId` / `ServicePrincipalId`	Aplicación o service principal que realizó la petición.
`IPAddress`	Dirección IP origen.
`RequestUri`	Recurso de Microsoft Graph solicitado.
`RequestMethod`	Método HTTP: GET, POST, PATCH, DELETE, etc.
`ResponseStatusCode`	Resultado HTTP de la petición.
`Scopes` / `Roles`	Permisos contenidos en el token.
`SessionId`	Sesión de autenticación asociada.
`SignInActivityId`	Permite correlacionar la petición con los sign-in logs.

1.3.3.4 Correlación con sign-in logs

Una capacidad especialmente importante es correlacionar:

Graph API activity + Microsoft Entra sign-in activity

utilizando:

`SignInActivityId`

Esto permite determinar:

- quién obtuvo el token;
- desde dónde se autenticó;
- qué llamadas Graph realizó posteriormente.

Conceptualmente:

Suspicious sign-in

⇓

Token/session

⇓

Microsoft Graph requests

1.3.3.5 Ejemplo: llamadas no autorizadas

Una gran cantidad de respuestas:

401 / 403

puede indicar intentos de acceder a recursos para los que una aplicación o identidad no dispone de permisos.

Ejemplo:

```
MicrosoftGraphActivityLogs
| where ResponseStatusCode in (401,403)
| summarize Requests=count()
by AppId, ServicePrincipalId, UserId
| sort by Requests desc
```

1.3.3.6 Escenarios típicos de examen

Escenario 1: se quiere conocer qué recursos Graph accedió una OAuth app sospechosa.

`MicrosoftGraphActivityLogs` → **AppId / ServicePrincipalId**

Escenario 2: una cuenta fue comprometida y se necesita determinar qué llamadas API realizó.

`MicrosoftGraphActivityLogs` → **UserId**

Escenario 3: se quiere relacionar una llamada Graph sospechosa con el inicio de sesión que obtuvo el token.

Correlacionar mediante `SignInActivityId`

Escenario 4: se necesita conocer qué permisos utilizó una aplicación durante una llamada.

`Scopes / Roles`